

Project Tracker

Source Handoff Review

Prepared for Tom Lagos | September 15, 2026
Local review of Faheem's September 14 source ZIP

Result: Core fixes pass local checks. Follow-up is needed on timeout accuracy, tab synchronization, and release traceability. The archive can be opened and built. This review does not establish that the ZIP matches the reported Git commit or the currently deployed production code.

What was verified

Item	Local result
Sign-out reliability	Passed: expired sessions and stale CSRF tokens can sign out; the session row is removed and the cookie is cleared.
Temporary-password screen exit	Sign out control and event wiring are present and covered by the supplied tests. The logout API works before the forced password change.
Administrator password reset	Passed: all existing sessions for the target user become invalid; another user's session survives. The replacement password works and requires a change.
Admin Login History	Passed: successful, failed, unmatched and logout events are available to Admin. Viewer access is denied. Search/filter/pagination code is present.
45-minute server timeout	Passed: the server rejects idle sessions, including attempts to renew after expiry. Other sessions remain active. Browser warning timing needs correction.
Tabs and background requests	Partial: read-only session probes do not extend idle time. Other GET routes do. Tabs can retain stale warnings and security tokens.
Reported source/deployment match	Unverified: no Git history in ZIP; manifest identifies an older source commit and existing file checksums are stale.

Test evidence and limits

npm test passed (build, ESM validation, supplied smoke suite). **npm run build:pages passed**; gzip bundle is 2,701,009 bytes. Node.js v24.19.0 was used. Seventeen additional checks ran: twelve confirmed expected behavior and five reproduced gaps or characterized limitations. Successful reproduction of an issue is not a passing acceptance result.

Additional tests used an in-memory SQLite database, synthetic login accounts, and the delivered browser functions with a simulated clock and minimal DOM. The full Windows Edge/Chrome/Firefox UI and real Cloudflare D1 were not independently exercised. No production deployment, live account, password, or business-data changes were made.

Session behavior requiring follow-up

Findings are grounded in the delivered source and local reproductions.

1. The warning can occur after the server has expired

Reproduced. `noteActivity()` resets the browser countdown on each input, but sends activity to the server at most once per 11 minutes 15 seconds at the 45-minute setting. The server therefore may use an earlier last-activity time than the browser.

Example time	Observed behavior
Minute 0	Input sends an activity ping. Server expiry is minute 45.
Minute 10	More input moves the browser expiry to minute 55. No new ping is sent.
Minute 45	Server session expires, only 35 minutes after the last input.
Minute 54	Browser warning is scheduled to appear, nine minutes after server expiry.

Requested correction: keep the warning tied to the server's authoritative remaining time and reliably record recent user activity. Verify the 45-minute idle period and one-minute warning after typing, scrolling, backgrounding a tab, and returning. Do not let automatic polling count as user activity.

Source: `worker/client.js:80-153` (particularly `noteActivity` at 132-140); `worker/index.js:279-317` and 978-989.

2. Tab resynchronization leaves an old security token

Reproduced. When another tab signs in, the shared cookie changes. The first tab can still hold the old CSRF token. `GET /api/session` succeeds but returns no replacement token; the first tab's Stay signed in POST then receives **403**. Its error handler sends the user to the sign-in screen even though the new server session is valid.

The client rechecks idle time when a tab becomes visible and when a countdown expires. It does not immediately broadcast sign-out/session changes. It also shows an inactivity warning before checking whether another tab has kept the shared session active.

Requested correction: synchronize session identity, sign-out and security-token changes between tabs; verify the shared session before showing a warning. Preserve isolation between separate browser sessions. Keep the backend's CSRF rejection in place.

Source: `worker/client.js:94-127`, 148-155 and 249-254; `worker/index.js:965-989`.

3. Background-request claim is broader than the code

`GET /api/session` correctly leaves `last_used_at` unchanged. However, a background `GET /api/bootstrap` resets it: the local test changed remaining idle time from about 300 seconds to 2,700 seconds. Only the `session-probe` route is exempt from this update.

The delivered client does not appear to run a recurring bootstrap poll, so this is a limitation of the stated guarantee, not evidence that today's normal screen already polls indefinitely. Restrict renewal to intentional activity, and add an automated regression test before adding background refresh behavior.

Handoff and acceptance notes

Resolve release identity and document the final corrected behavior.

Release traceability

Faheem reported Git commit:

378eaba07590636afb4f17c3404a3eb18038fa6b

Reported Cloudflare production deployment:

40f0d7f2-8691-49fb-869c-fe90b0382fb3

The ZIP has no .git history. HANDOFF_MANIFEST.json is dated September 8 and lists source commit 514f5f0c CHECKSUMS.sha256 contains **32 matching and 11 mismatching files**; current docs acknowledge an older single-file divergence. These retained records do not verify this release. The older 0df74aa filename alone does not prove a source mismatch.

Request: an updated manifest and regenerated checksums for the actual final source, plus repository access or an authenticated comparison against the stated commit. Tie the final tested commit to its Cloudflare deployment. Any further code correction will normally produce a new commit.

Documentation and packaging

The eight operational guides are present, including COST_AND_LIMITS.md as the Cloudflare cost guide. TESTING.md describes server timeout behavior and claims Windows Edge, Chrome and Firefox verification; those claims were not independently reproduced on those browsers. The supplied automated test file covers the first four fixes but contains no dedicated idle-timeout regression tests.

BACKUP_AND_RESTORE.md documents a September 11 restoration of an Admin-downloaded backup into separate D1, with dependency ordering and deferred foreign keys. The supplied local smoke test includes backup checks. No new remote D1 or R2 restoration was run during this review.

No live API token or private key was identified by a targeted text-pattern scan; the seeded directory has no configured passwords. A fixed **local-only** test password remains in pages-test/setup.sh. This is not evidence that it is a live password. Replace the fixed default with a generated or explicitly supplied value to meet the requested clean-source handoff. A pattern scan is not a complete secrets audit.

Login History currently retrieves only the newest 200 events; its search and pagination operate on that subset. Document this limit or add server-side history paging if older login records must be searchable.

Suggested final acceptance checks

1. Re-run the supplied suite plus regression tests for countdown drift, old-tab CSRF, shared-session logout and background requests.
2. Demonstrate the corrected warning and timeout on Windows Edge using separate test accounts.
3. Deliver source, manifest and checksums for the same final commit, with deployment identification.
4. Keep all existing tester accounts and passwords unchanged during verification.

Archive examined

DN-Project-Tracker-0df74aa-handoff.zip | 3,402,854 bytes

ZIP integrity check passed. SHA-256:

62e6e2a9c222154fd9a3af0d3545eae533c5a6322f1211f0ef901d9d96f4209a